

# Cloud Security Monitoring

FIG\_000 · guide v1.0 · 2026 · open reference · 9 sections

by Swastik Sagar

There's no physical host to triage and no packet capture on someone else's network – CloudTrail, identity-centric attacks, native detection services, and what actually changes when the perimeter is an API.

```
$ read section_01 --start
```

## WHAT'S INSIDE

| SECTION | TOPIC                                                           |
|---------|-----------------------------------------------------------------|
| 1 – 2   | Why cloud monitoring differs, and the core audit log services   |
| 3 – 4   | Identity/access monitoring, and cloud-native detection services |
| 5 – 7   | Common attack patterns, log aggregation, and posture management |
| 8 – 9   | A worked cloud-compromise detection, and reference              |

**How to use this guide:** read start to finish for the full picture, or jump to Section 8 for the worked detection walkthrough. Every diagram is numbered and referenced directly in the surrounding text.

# Table of Contents

|                                                 |    |
|-------------------------------------------------|----|
| 1. Why Cloud Monitoring Is Different            | 3  |
| 2. Cloud Audit Logs                             | 4  |
| 3. Identity & Access Monitoring                 | 5  |
| 4. Cloud-Native Detection Services              | 6  |
| 5. Common Cloud Attack Patterns                 | 7  |
| 6. Multi-Cloud & Hybrid Log Aggregation         | 8  |
| 7. Cloud Security Posture Management            | 9  |
| 8. Worked Example: Detecting a Cloud Compromise | 10 |
| 9. Quick Reference & Glossary                   | 11 |

This guide is designed to be read section by section, with diagrams positioned next to the concepts they illustrate.

# Why Cloud Monitoring Is Different

---

## 1.1 NO HOST TO STAND IN FRONT OF

Every triage technique in the Linux for SOC Analysts and Windows Event Log Reference guides assumes something concrete: a host you can log into, a disk you can image, a network you can capture packets from directly. In the cloud – especially with managed/serverless services – that host often doesn't exist in any form you can access at all. Monitoring shifts almost entirely to **API-level activity logs**: not "what did this process do," but "what API calls were made, by whom, against what resource."

## 1.2 THE SHARED RESPONSIBILITY MODEL

Cloud providers secure the underlying infrastructure (the physical hosts, the hypervisor, the network fabric described in the Cloud Networking guide); the customer is responsible for securing what they configure on top of it – identity, data, network rules (security groups/NACLs, Cloud Networking guide Section 4), and application code. Monitoring follows this same split: you generally can't see the provider's infrastructure layer at all, but you get comprehensive logging of everything happening at your layer, if it's enabled.

**Cloud audit logging is rarely fully enabled by default.** Directly echoing the Windows Event Log Reference guide's Section 1.3 point about audit policy, most cloud platforms require explicit configuration to capture the full range of API activity, retain it for a useful period, and route it somewhere durable. An unconfigured logging service is, for detection purposes, no different from a Windows host with auditing disabled – invisible until it's turned on.

## 1.3 IDENTITY BECOMES THE NEW PERIMETER

Without a traditional network boundary to defend, **identity and access management** becomes the primary control plane attackers target and defenders must monitor – a theme this entire guide returns to repeatedly, and the specific focus of Section 3.

# Cloud Audit Logs

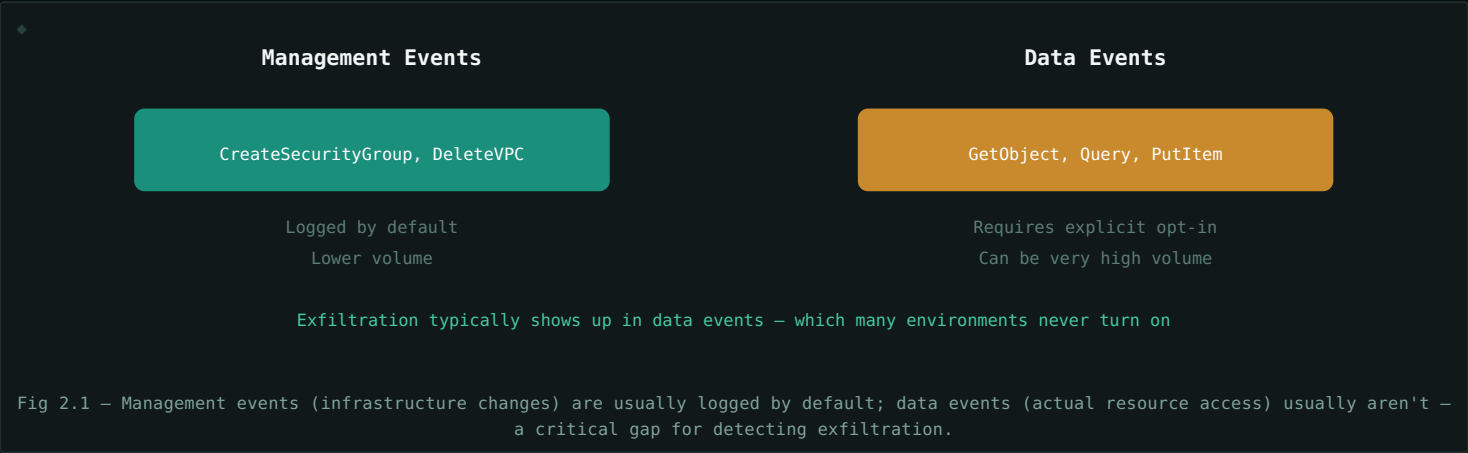
## 2.1 THE PROVIDER-SPECIFIC EQUIVALENTS

Each major cloud provider has its own audit logging service, all conceptually equivalent to the Windows Security Event Log's role covered in the Windows Event Log Reference guide – a record of who did what, when, to which resource.

| PROVIDER | SERVICE          | RECORDS                                                                                |
|----------|------------------|----------------------------------------------------------------------------------------|
| AWS      | CloudTrail       | Every API call made against the account, management and (optionally) data-plane events |
| Azure    | Activity Log     | Subscription-level operations – resource creation, modification, deletion              |
| GCP      | Cloud Audit Logs | Admin activity, data access, and system events across the project                      |

## 2.2 MANAGEMENT EVENTS VS DATA EVENTS

Nearly all cloud audit services distinguish between **management/control-plane events** (creating a VPC, modifying a security group – administrative actions on the cloud resources themselves) and **data-plane events** (reading an object from storage, a database query). Management events are typically logged by default; data-plane events often require explicit, separate configuration and can generate dramatically higher log volume.



## 2.3 LOG INTEGRITY: THE SAME TAMPERING CONCERN, CLOUD VERSION

Just as the Linux for SOC Analysts guide's Section 5.3 warned that an attacker with root access can tamper with local logs, an attacker with sufficient cloud privileges can disable or delete audit logging entirely – which is why routing logs to a separate, access-restricted storage location (and alerting on any attempt to modify the logging configuration itself) is standard, essential practice, not an optional hardening step.

# Identity & Access Monitoring

## 3.1 IAM IS THE NEW WINDOWS EVENT ID 4624

Where the Windows Event Log Reference guide's Section 2 covers logon events as the core Windows detection surface, cloud environments have a direct equivalent centered on **IAM (Identity and Access Management)** activity – authentication events, role/permission changes, and credential usage, all captured in the audit logs from Section 2.

## 3.2 WHAT TO ACTUALLY WATCH

| EVENT TYPE                                                             | WHY IT MATTERS                                                                                                                                     |
|------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| Console logins from unusual locations                                  | The cloud equivalent of an unexpected Logon Type in Windows Event ID 4624 (Windows Event Log Reference guide, Section 2.2)                         |
| New access key / credential creation                                   | A common persistence mechanism – directly analogous to the SSH <code>authorized_keys</code> check in the Linux for SOC Analysts guide, Section 7.3 |
| Privilege/role escalation (a user or role gaining broader permissions) | The cloud equivalent of Windows Event ID 4732 (Windows Event Log Reference guide, Section 3.2)                                                     |
| Programmatic (API key/service account) activity from an unusual source | Machine identities are just as attackable as human ones, and often less closely watched                                                            |

## 3.3 THE DANGER OF LONG-LIVED CREDENTIALS

A static, long-lived access key – unlike a session that naturally expires – remains valid indefinitely once created, making it an especially attractive persistence mechanism if an attacker gains sufficient privilege to create one. This is why many cloud security programs push toward short-lived, automatically-rotating credentials (temporary session tokens, workload identity federation) specifically to shrink this window, rather than relying purely on detecting misuse of a credential that may remain valid for months or years.

**One over-privileged identity is worth more to an attacker than one compromised host.** Because so much of cloud infrastructure is reachable purely through API calls, a single compromised identity with broad permissions can affect vastly more resources than compromising any individual server ever could in a traditional on-prem environment – which is exactly why identity monitoring, not host monitoring, is this guide's central theme.

# Cloud-Native Detection Services

## 4.1 BUILT-IN THREAT DETECTION

Beyond raw audit logs (Section 2), major cloud providers offer managed threat detection services that analyze account activity for known-malicious patterns automatically – a cloud-native parallel to the SIEM correlation rules covered in the SIEM & Log Analysis guide, but pre-built and maintained by the provider rather than authored in-house.

| PROVIDER | SERVICE                      | DETECTS                                                                        |
|----------|------------------------------|--------------------------------------------------------------------------------|
| AWS      | GuardDuty                    | Anomalous API activity, known-malicious IPs, compromised credential indicators |
| Azure    | Microsoft Defender for Cloud | Threat detection across compute, identity, and data services                   |
| GCP      | Security Command Center      | Threats, vulnerabilities, and misconfigurations across the project             |

## 4.2 NATIVE DETECTION ISN'T A COMPLETE REPLACEMENT

These services are genuinely valuable – pre-built detections informed by the provider's visibility across their entire customer base, not just your environment – but they don't replace the custom, environment-specific detection engineering covered in the Detection Engineering guide. A native service catches broadly known-bad patterns; it has no way to know that a specific API call sequence is unusual specifically *for your organization's normal behavior*, which is exactly the kind of context custom correlation rules (SIEM & Log Analysis guide, Section 5) are built to add.

## 4.3 FEEDING NATIVE DETECTIONS INTO YOUR OWN PIPELINE

Most of these services can forward their findings into your own SIEM alongside audit logs and custom correlation rules – treating native detection output as one more input into the same enrichment and correlation pipeline (SIEM & Log Analysis guide, Section 2) rather than a separate, disconnected alert queue analysts have to check independently.

**Native detection coverage varies enormously by service and by provider.** A cloud environment using dozens of managed services has wildly inconsistent native detection depth across them – treating "we have GuardDuty enabled" as equivalent to comprehensive coverage is the cloud-specific version of the false confidence a shallow coverage map produces (Detection Engineering guide, Section 7.3).

# Common Cloud Attack Patterns

## 5.1 EXPOSED CREDENTIALS

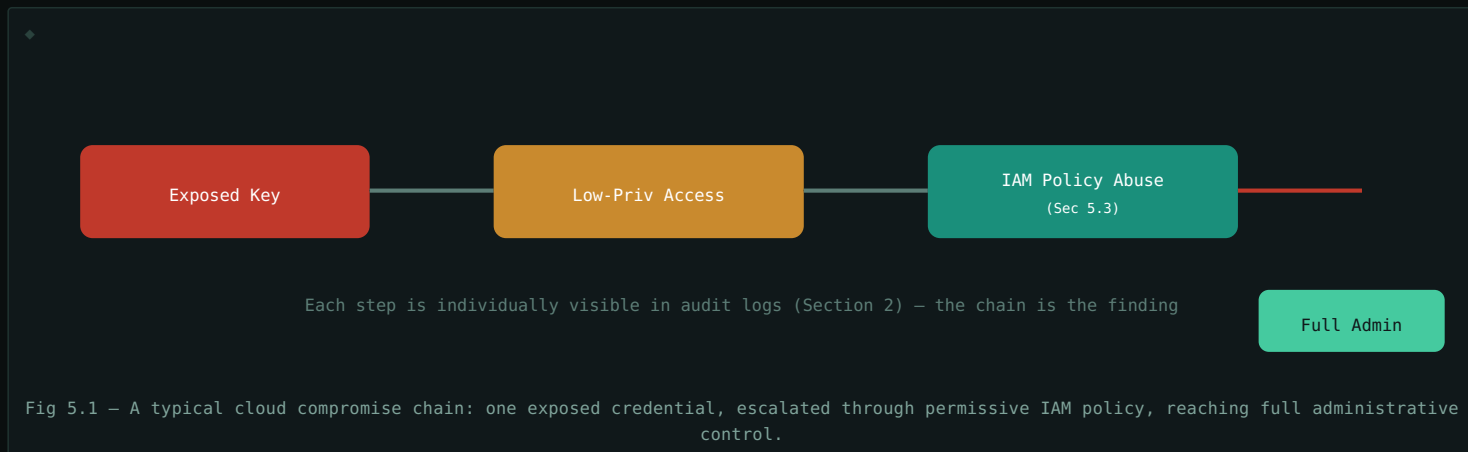
Cloud access keys accidentally committed to a public code repository, embedded in a mobile app, or left in an unsecured configuration file remain one of the single most common cloud compromise vectors – the resulting activity is almost always visible in audit logs (Section 2) as API calls from an unfamiliar source using a valid, legitimate credential, which is precisely why identity monitoring (Section 3) matters more than network-based detection here.

## 5.2 MISCONFIGURED STORAGE

A storage bucket or container accidentally left publicly readable is a direct, immediate data exposure – no compromise of any credential required at all. This ties directly to the Cloud Networking guide's Section 4 coverage of security groups/NACLs, and is exactly the class of issue Section 7's posture management tooling is designed to catch proactively, before an attacker (or a search engine) finds it first.

## 5.3 PRIVILEGE ESCALATION VIA MISCONFIGURED IAM POLICIES

Overly permissive IAM policies – a role that can modify its own permissions, or one with broader access than its actual function requires – let an attacker who compromises even a low-privilege identity escalate to far greater access, echoing Section 3.3's point about the outsized value of a single over-privileged identity in cloud environments specifically.



## 5.4 SERVERLESS & SUPPLY CHAIN RISKS

Serverless functions and managed services introduce attack surface with no traditional host to monitor at all – a vulnerable dependency inside a function's code, or a compromised third-party integration with excessive permissions, can be exploited without ever touching anything resembling a conventional server. Detection here relies almost entirely on the function's own execution logs and the IAM permissions it was granted (Section 3), reinforcing this guide's identity-centric theme once again.

# Multi-Cloud & Hybrid Log Aggregation

## 6.1 THE FRAGMENTATION PROBLEM

An organization running workloads across AWS, Azure, on-premises infrastructure (Linux for SOC Analysts guide), and Windows environments (Windows Event Log Reference guide) has security-relevant logs scattered across entirely different formats, retention policies, and access mechanisms – CloudTrail, Activity Log, syslog, and the Windows Event Log all describing conceptually similar activity in completely different shapes.

## 6.2 THE SAME NORMALIZATION PROBLEM, LARGER SCALE

This is precisely the normalization challenge covered in the SIEM & Log Analysis guide's Section 6 – mapping each source's own field names onto a shared schema – just spanning cloud and on-prem sources simultaneously rather than a handful of on-prem log types. A "who performed this action" field means `userIdentity.arn` in CloudTrail, `caller` in Azure Activity Log, and `TargetUserName` in a Windows Event Log (Windows Event Log Reference guide, Section 2.1) – all needing to converge on one normalized `user` field for cross-environment correlation to work at all.

## 6.3 CENTRALIZING WITHOUT LOSING FIDELITY

| APPROACH                                                    | TRADE-OFF                                                                                      |
|-------------------------------------------------------------|------------------------------------------------------------------------------------------------|
| Forward everything to one central SIEM                      | Best correlation capability, but highest volume/cost and requires broad normalization coverage |
| Per-cloud native tooling, federated queries                 | Lower overhead per source, but weaker cross-environment correlation                            |
| Hybrid – critical events centralized, rest queried natively | Balances cost and coverage, requires deliberate decisions about what counts as "critical"      |

**An attack that spans environments is exactly what fragmented logging misses.** An identity compromised in one cloud, used to pivot into an on-prem system via a hybrid connection (Cloud Networking guide, Section 7), produces a trail that's only visible if both environments' logs are actually correlated together – which is the whole reason aggregation matters more than any single source's log quality alone.



# Cloud Security Posture Management

## 7.1 FINDING MISCONFIGURATIONS BEFORE THEY'RE EXPLOITED

CSPM (Cloud Security Posture Management) tooling continuously scans a cloud environment's configuration against security best practices and compliance benchmarks – flagging exactly the kind of issues covered in Section 5.2 and 5.3 (public storage, over-permissive IAM) proactively, before they become the entry point for an actual attack.

## 7.2 DETECTION VS POSTURE MANAGEMENT

This is a meaningfully different discipline from everything covered in Sections 2–6: detection (audit logs, native services, correlation rules) answers "is something bad happening right now"; posture management answers "is something exploitable sitting there waiting to happen." Both matter, and mature cloud security programs run them together – posture management shrinking the attack surface, detection catching what still gets through.

| ASPECT            | DETECTION (SECTIONS 2–6)          | POSTURE MANAGEMENT (THIS SECTION)   |
|-------------------|-----------------------------------|-------------------------------------|
| Question answered | Is an attack happening?           | Is there an exploitable weakness?   |
| Timing            | Reactive to activity              | Continuous, independent of activity |
| Data source       | Audit logs, alerts (Section 2, 4) | Resource configuration state        |

## 7.3 COMMON CHECKS

- Publicly accessible storage buckets/containers with sensitive data
- IAM policies granting overly broad permissions (Section 5.3), or unused, stale credentials that should have been revoked
- Security groups/NACLs (Cloud Networking guide, Section 4) with unnecessarily permissive rules
- Missing encryption at rest or in transit on sensitive resources
- Disabled or misconfigured audit logging (Section 2.3's tampering concern, caught proactively instead of after the fact)

**CSPM findings need the same prioritization discipline as detection alerts.** A CSPM scan across a large cloud environment can surface hundreds of findings – treating every one as equally urgent produces the exact same alert-fatigue problem covered in the SIEM & Log Analysis guide's Section 7.1, just applied to configuration findings instead of behavioral alerts. Risk-based prioritization (is this resource internet-facing, does it hold sensitive data) matters just as much here.

## Worked Example: Detecting a Cloud Compromise

A CSPM scan (Section 7) flagged an IAM role with excessive permissions two weeks ago, not yet remediated. Walking the detection flow built across this guide:

1. **Initial access (Section 5.1):** an access key for a low-privilege service account is found exposed in a public code repository by an attacker.
2. **Audit log trail begins (Section 2):** CloudTrail records API calls using that key from an unfamiliar IP address – the first visible signal, though nothing has fired an alert yet at this point.
3. **Native detection service fires (Section 4.1):** GuardDuty flags the unfamiliar source as an anomalous API caller for this credential – a broad, provider-level signal.
4. **Privilege escalation (Section 5.3):** using the over-permissive role flagged (but not yet fixed) by Section 7's CSPM scan, the attacker grants the compromised identity broader access – visible in audit logs as an IAM policy modification event.
5. **Custom correlation rule fires (Section 4.2, SIEM & Log Analysis guide Section 5):** a rule specifically built to detect "API activity from a new source IP, immediately followed by a permission change on the same identity" – the same specificity principle from the Detection Engineering guide's Section 3.3 – fires a high-confidence alert.
6. **Cross-environment correlation (Section 6):** log aggregation reveals the same credential's activity also touched an on-prem system via a hybrid connection (Cloud Networking guide, Section 7) – a finding that would have been invisible without Section 6's cross-environment log correlation.
7. **Handoff to IR (Incident Response Playbook Companion guide):** full incident response begins, with the CSPM finding from two weeks prior now flagged for immediate remediation as part of Section 6 of that guide's Lessons Learned phase.

**Every layer contributed something the others couldn't.** The native service (Section 4) caught the anomaly broadly and fast; the custom rule (Section 4.2) added environment-specific precision; posture management (Section 7) had already flagged the exploited weakness before it was ever used; and log aggregation (Section 6) revealed the full cross-environment blast radius. No single layer in this guide would have told the complete story alone.

# Quick Reference & Glossary

| TERM                                                     | DEFINITION                                                                                                            |
|----------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| Shared Responsibility Model                              | The division of security duties between cloud provider (infrastructure) and customer (configuration, identity, data). |
| CloudTrail / Activity Log / Cloud Audit Logs             | AWS/Azure/GCP's respective services recording API activity across an account.                                         |
| Management Event                                         | An audit log entry for an administrative action on cloud resources themselves.                                        |
| Data Event                                               | An audit log entry for access to the actual data within a resource (e.g., reading a storage object).                  |
| IAM                                                      | Identity and Access Management – the system controlling who can do what in a cloud environment.                       |
| GuardDuty / Defender for Cloud / Security Command Center | AWS/Azure/GCP's respective native, managed threat detection services.                                                 |
| CSPM                                                     | Cloud Security Posture Management – continuous scanning for exploitable misconfigurations.                            |
| Privilege Escalation                                     | Gaining greater access than originally granted, often via a misconfigured permission.                                 |
| Log Aggregation                                          | Centralizing logs from multiple cloud/on-prem sources for unified correlation.                                        |

**End of guide.** Nearly every section here traced back to the same point made in Section 1.3: identity is the perimeter now. Whatever specific tool or provider you're working with, the question worth asking first is always the same one – who can do this, and would we actually notice if they shouldn't have been able to.